

Relazione tecnica di Vulnerability Assessment

*Analisi,
mitigazione e
verifica della
conformità
infrastrutturale
dell'asset Target*
Data: 27/06/2026
Autore: Alessandro
Accordino

28 GIUGNO

Finalità del progetto

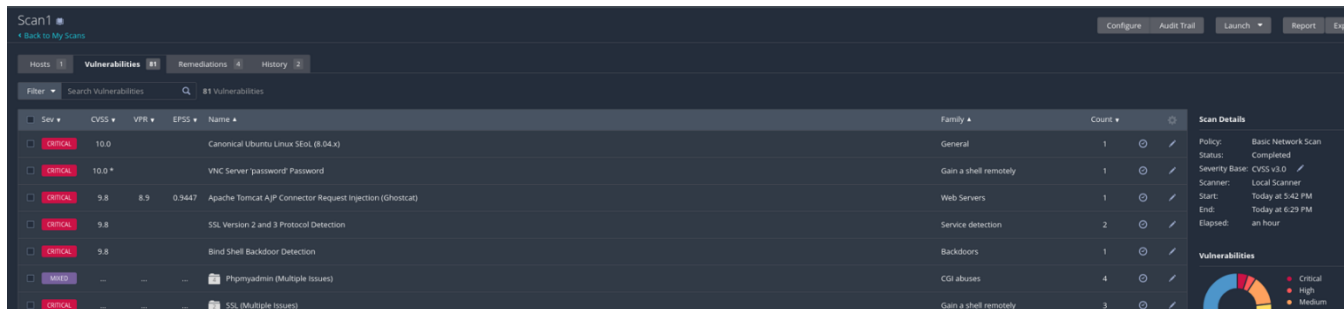
Lo scopo principale di questo progetto è valutare la debolezza del sistema ed eseguire varie strategie per ridurre i rischi. Il documento è il risultato delle attività di Vulnerability Assessment(VA) e Remediation condotte sul sistema Metasploitable 2, che ha l'indirizzo IP locale 192.168.50.101.

L'obiettivo principale è: da un lato, mappare la superficie d'attacco esposta del sistema, con i vari modi in cui potrebbe essere attaccato, e dall'altro, implementare strategie per ridurre i rischi e mettere in sicurezza la macchina. Questo significa analizzare i punti deboli del sistema e trovare soluzioni per proteggerlo.

Informazioni Target

Parametro	Valore
Nome Sistema	— Metasploitable 2
Indirizzo IP	— 192.168.50.101
Sistema Operativo	— Ubuntu 8.04 LTS(Hardy Heron) Server Edition
Tipo Ambiente	— Virtual Machine - Lab
Rete	— Segmento Isolato (Intranet)
Strumento di Scan	— Nessus
—	
—	
—	
—	
—	

Scansione Iniziale



In data 27 Giugno 2026 è stata condotta una valutazione delle vulnerabilità (VA) sul sistema target “192.168.50.101”.

La scansione è stata portata a termine tramite un “basic network scan” di **TUTTE LE PORTE** del target e ha identificato 5 vulnerabilità **CRITICHE** che espongono il sistema a rischi significativi di compromissione totale, esfiltrazione di dati e interruzione dei servizi. Per il progetto verranno scelte queste 5 principali vulnerabilità nonostante ce ne siano ulteriori messe a disposizione dalla metasploitable 2.

Riassunto Vulnerabilità:

ID Plugin Nessus	Severità	Porta / Protocollo	Servizio Rilevato	Descrizione Sintetica della Minaccia	Stato della Falla
61708	CRITICO (10.0)	5900 / TCP	VNC Server	Autenticazione superata usando la password di default password. Garantisce il controllo grafico remoto.	Da Risolvere
51988	CRITICO (10.0)	1524 / TCP	Bind Shell	Presenza di una backdoor attiva che fornisce una shell con privilegi di root senza alcuna autenticazione.	Da Risolvere
134862	CRITICO (10.0)	8009 / TCP	Apache Tomcat AJP	Vulnerabilità Ghostcat. Permette la lettura di file riservati e l'esecuzione di codice arbitrario (RCE).	Da Risolvere
201352	CRITICO (10.0)	80 / TCP	HTTP Server	Sistema Operativo a fine vita (End-of-Life). Ubuntu 8.04 non riceve patch di sicurezza dal 2013.	Da Risolvere
20007	CRITICO (10.0)	443 / TCP 25-5432/TCP	SSL Services	Abilitazione di protocolli obsoleti e insicuri (SSLv2 e SSLv3) soggetti ad attacchi di decifratura dati e furto credenziali.	Da Risolvere

Dettaglio delle Vulnerabilità Identificate

1) Vulnerabilità VNC (Nessus Plugin #61708)

- Nome Vulnerabilità: VNC Server ‘password’ Password.

-
- **Identificativo Nessus: Plugin ID 61708**
 - **Codice CVE (Common Vulnerabilities Exposures): Non ha un codice CVE univoco si tratta di una misconfiguration(Errore di configurazione umana/credenziali deboli)**
 - **Severità: Critica (CVSS massimo:10.0)**

Il servizio VNC (Virtual Network Computing) sulla porta 5900/TCP è un sistema di controllo remoto grafico, **simile al Desktop remoto di Windows**. Permette a un utente di vedere lo schermo del server e muovere mouse e tastiera a distanza ed eventualmente ottenere il controllo remoto totale.

1.1 Attacco:

Nessun ha effettuato una scansione automatica sulla porta 5900/TCP e ha tentato un attacco brute force di tipo dictionary dove ha provato tramite le credenziali più comuni ad entrare. Il server ha accettato come password di autenticazione la parola stessa password dando una password banale e senza nemmeno richiedere un nome utente, in questa maniera ha dato il pieno accesso allo scanner.

1.2 Rischi:

L'impatto della vulnerabilità sul server è catastrofico e può compromettere in maniera irreparabile il sistema.

Controllo totale remoto: Un attaccante senza aver bisogno di exploit complessi gli basterebbe scaricare un qualsiasi VNC gratuito come RealVNC e inserire l'IP 192.168.50.101 e digitare "**password**" per trovarsi dentro il desktop della macchina con i privilegi massimi(root).

Esfiltrazione e Compromissione dei Dati: Banalmente una volta all'interno della macchina l'attaccante può rubare file, installare malware, keylogger per registrare i tasti e rubare ulteriori password o usare la macchina per Lateral Movement (Movimento Laterale) per riuscire ad attaccare gli altri host della rete.

2) Vulnerabilità Bind Shell

- **Nome Vulnerabilità: Vulnerabilità Bind Shell Backdoor Detection**
- **Identificativo Nessus: Plugin ID 51988**

- **Codice CVE (Common Vulnerabilities Exposures):** Non ha un codice CVE univoco si tratta di una compromissione già avvenuta precedentemente
- **Classificazione CWE (Common Weakness Enumeration):** CWE-1329: *Reliance on Component Past End-Of-Life* / CWE-912.
<https://cwe.mitre.org/data/definitions/287.html>
- **Severità: Critica (CVSS massimo:10.0)**

Il servizio responsabile è attivo sulla porta 1524/TCP sull'host target 192.168.50.101. Una Bind Shell è un processo malevolo che permette all'attaccante di collegarsi tramite una porta di rete mentre l'host rimanere in ascolto (Listening) di connessioni esterne. Tutto questo avviene sfruttando una vulnerabilità dell'host target che permette di eseguire uno script che consente di aprire una porta nella macchina target e di legarla (da qui Bind) alla shell di sistema. Semplicemente la vittima agisce come un Server mentre l'attaccante come un Client e una volta stabilita la connessione l'attaccante ottiene l'accesso alla riga di comando del target.

2.1 Attacco:

Nessun si è connesso alla porta 1524/TCP e il target ha risposto immediatamente aprendo una sessione di terminale(shell) senza richiedere alcun tipo di autenticazione. Questo dimostra che chiunque si colleghi a quella porta acquisisce immediatamente i privilegi di amministratore (root).

2.2 Rischi:

La presenza di una bind shell con privilegi di root distrugge immediatamente ogni difesa perimetrale del sistema. Non c'è bisogno di indovinare password né di sfruttare codici complessi.

Esecuzione Remota di Codice(RCE): Un attaccante può inviare qualsiasi comando direttamente tramite netcat e prendere il controllo.

Esfiltrazione e Spionaggio: Avendo i privilegi massimi l'attaccante può leggere i file protetti del sistema come /etc/shadow e ottenere le password degli utenti e monitorare il traffico della rete in tempo reale.

3) Vulnerabilità Ghostcat

- **Nome Vulnerabilità: Apache Tomcat AJP Connector Request Injection (Ghostcat)**
- **Identificativo Nessus: Plugin ID 134862**

- **Codice CVE (Common Vulnerabilities Exposures): CVE-2020-1945**
- **Classificazione CWE (Common Weakness Enumeration): CWE-20: Improper Input Validation]** <https://cwe.mitre.org/data/definitions/287.html> / **CWE-94: Improper Control of Generation of Code**
- **Severità: Critica (CVSS massimo:10.0)**

La vulnerabilità colpisce il servizio Apache Tomcat attivo sull'host 192.168.50.101 sulla porta 8009/TCP, dove è in ascolto il protocollo AJP (Apache JServ Protocol). L'APJ è un protocollo binario, quando un server web front-end (come Apache) riceve una richiesta http da un utente, la traduce in un pacchetto binario AJP e la inoltra a Tomcat sulla porta 8009, la vulnerabilità risiede nel fatto che Tomcat quando riceve un pacchetto dalla porta 8009 non esegue nessuna validazione/controllo e si fida in maniera assoluta del fatto che sia affidabile. Un attaccante può quindi inviare un pacchetto AJP modificato direttamente alla porta 8009.

Reference: <https://access.redhat.com/solutions/4851251>

3.1 Attacco:

Nessun è riuscito con successo a sfruttare il protocollo AJP inviando una richiesta forzata mostrata nell' output esadecimale:

```

Output

Nessus was able to exploit the issue using the following request :

0x0000:  02 02 00 08 48 54 54 50 2F 31 2E 31 00 00 0F 2F      ....HTTP/1.1.../
0x0010:  61 73 64 66 2F 78 78 78 78 78 2E 6A 73 70 00 00      asdf/xxxxx.jsp..
0x0020:  09 6C 6F 63 61 6C 68 6F 73 74 00 FF FF 00 09 6C      .localhost....l
0x0030:  6F 63 61 6C 68 6F 73 74 00 00 50 00 00 09 A0 06      ocalhost..P....
0x0040:  00 0A 6B 65 65 70 2D 61 6C 69 76 65 00 00 0F 41      ..keep-alive...A
0x0050:  63 63 65 70 74 2D 4C 61 6E 67 75 61 67 65 00 00      ccept-Language..
0x0060:  0F 65 6E 7D 5E 53 7C 6E 6E 7B 73 7D 7C 7E 00      ..US-...E
more...

```

A causa di un difetto logico descritto prima nel codice di Tomcat, il server tratta in maniera errata i parametri di questa richiesta binaria come dati affidabili e sicuri. Questo permette ad un attaccante di leggere o eseguire codice remoto.

3.2 Rischi:

l'impatto di Ghostcat si sviluppa su due livelli di gravità:

File Read / Arbitrary File Inclusion: Un attaccante può leggere da remoto qualsiasi file presente all'interno delle directory dell'applicazione web.

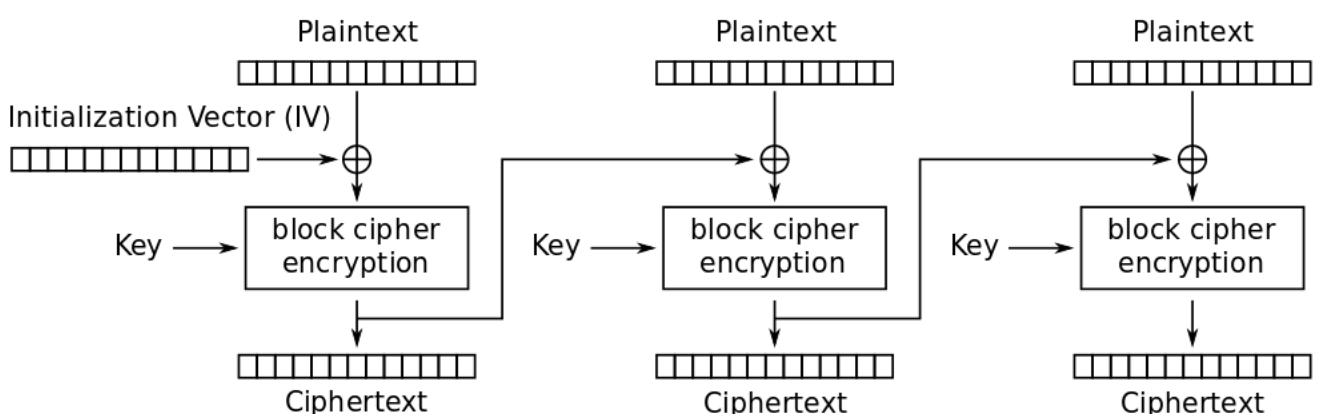
Remote Code Execution(RCE): se l'applicazione web permette di effettuare upload agli utenti questo permetterà all'attaccante di caricare qualsiasi tipo di file come malware

vari, per esempio può caricare un file dannoso (come una web shell) e sfruttare Ghostcat(vulnerabilità della porta 8009) costringere Tomcat a eseguirlo ottenendo il controllo.

4) Vulnerabilità SSLv2 e SSLv3

- **Nome Vulnerabilità: SSL Version 2 and 3 Protocol Detection**
- **Identificativo Nessus: Plugin ID 20007**
- **Codice CVE (Common Vulnerabilities Exposures): CVE-2014-3566 (conosciuta come la falla POODLE legata a SSLv3) e CVE-2016-0800 (conosciuta come l'attacco DROWN legato a SSLv2).**
- **Classificazione CWE (Common Weakness Enumeration): [CWE-326: Inadequate Encryption Strength](#) / [CWE-310: Cryptographic Issues \(Uso di algoritmi o protocolli crittografici deboli e obsoleti\)](#).**
- **Severità: Critica (CVSS massimo:10.0)**

I protocolli SSLv2(1995) e SSLV3(1996) sono standard crittografici obsoleti e ormai deprecati sostituiti dal protocollo TLS. Questi protocolli presentano gravi vulnerabilità nell'Handshake e nell'integrità dei messaggi. Un grave difetto in SSLv3 è che quando vengono inviati dei dati protetti, la crittografia ha bisogno di dividerli in blocchi uguali e per riuscirci utilizza una tecnica chiamata **padding** che consiste nell'utilizzare una sequenza riempitiva di bit, ma in questi protocolli non viene controllata permettendo ad un attaccante che abbia intercettato il pacchetto di modificare i byte del padding (Questa Famosa Vulnerabilità è chiamata **POODLE**) e inviarlo al server o di forzare la decifratura dei dati senza avere la chiave privata.



Cipher Block Chaining (CBC) mode encryption

4.1 Attacco:

Nessus ha avviato una sessione di negoziazione crittografica (SSL Handshake) forzando i parametri di connessione verso gli standard SSLv2 e SSLv3 (**Downgrade Attack**) ed enumerando le Cipher suite (elenchi di Algoritmi di cifratura) a bassa resistenza (es. DES). Il target ha risposto positivamente completando l'Handshake, confermando l'accettazione di protocolli deprecati e fornendo l'evidenza tecnica necessaria per decretare il fallimento del livello di sicurezza crittografica dell'host.

```
Output

- SSLv2 is enabled and the server supports at least one cipher.

Low Strength Ciphers (<= 64-bit key)

Name           Code      KEX      Auth      Encryption      MAC
-----
EXP-RC2-CBC-MD5  RSA      RSA      RC2-CBC(40)    MD5      export
EXP-RC4-MD5      RSA      RSA      RC4(40)        MD5      export
more...

To see debug logs, please visit individual host
Port ▲        Hosts
25 / tcp / smtp 192.168.50.101

- SSLv3 is enabled and the server supports at least one cipher.
  Explanation: TLS 1.0 and SSL 3.0 cipher suites may be used with SSLv3

Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)

Name           Code      KEX      Auth      Encryption      MAC
-----
EXP-RC2-CBC-MD5  RSA      RSA      RC2-CBC(40)    MD5      export
EXP-RC4-MD5      RSA      RSA      RC4(40)        MD5      export
more...

To see debug logs, please visit individual host
Port ▲        Hosts
5432 / tcp / postgresql 192.168.50.101
```

4.2 Rischi:

Attacchi del tipo Man-In-the-Middle(MitM)

Intercettazione di traffico: Un attaccante posizionato nella stessa rete tramite **ARP spoofing**(Messaggi ARP Falsi per ottenere ed intercettare pacchetti) nella stessa LAN o rete in bridge può intercettare la sessione ed eseguire un attacco di tipo Downgrade (esattamente come fatto nella scansione) forzando il browser del client e il server a comunicare utilizzando SSLv3 invece di TLS.

Violazione della riservatezza: una volta forzato l'uso del protocollo debole, l'attaccante può sfruttare le falle matematiche del padding o dei cifrari per decifrare in chiaro cookie di sessione e le credenziali compromettendo tutto il sistema.

5) Vulnerabilità Ubuntu Linux SEoL - 8.04.x

- Nome Vulnerabilità: Canonical Ubuntu Linux SEoL - 8.04.x
- Identificativo Nessus: Plugin ID 201352

- **Codice CVE (Common Vulnerabilities Exposures): Non applicabile (N/A).**
Rappresenta uno stato di obsolescenza totale del sistema
- **Classificazione CWE (Common Weakness Enumeration): [CWE-1329: Reliance on Component Past End-of-Life](#)** (Affidamento su un componente informatico che ha superato la data di fine vita).
- **Severità: Critica (CVSS massimo:10.0)**

5.1 Dettagli:

La vulnerabilità riguarda l'intero host target 192.168.50.101. Lo scanner Nessus, analizzando le risposte dei servizi ha identificato la versione del sistema operativo in esecuzione: Ubuntu Linux 8.04.

L'evidenza dell'output di Nessus ci fa capire la gravità della vulnerabilità:

Output

```
OS : Ubuntu Linux 8.04
Security End of Life : May 9, 2013
Time since Security End of Life (Est.) : >= 13 years
```

Il termine SEoL (Security End Of Life) indica che il produttore ha interrotto definitivamente il rilascio di qualsiasi tipo di patch, aggiornamenti di sicurezza o supporto tecnico.

5.2 Rischi:

Esposizione Totale a Exploit Noti ed Emergenti

L'impatto di un sistema operativo SEoL è un impatto distruttivo per il sistema:

- **Assenza di Patch:** Qualsiasi nuova vulnerabilità scoperta dal 2013 a oggi rimarrà perennemente aperta e sfruttabile dato che il sistema non riceve aggiornamenti. Il sistema è completamente indifendibile.
- **Privilege Escalation Locale (LPE):** Un attaccante che riesce ad accedere al sistema con un utente con privilegi minimi può usare uno delle centinaia di exploit locali del kernel pubblicati negli ultimi 13 anni per diventare immediatamente amministratore (root) e fare quello che vuole, compromettendo la macchina.

PIANO DI REMEDIATION

Questa sezione descrive le contromisure e tecniche applicate sull'host target 192.168.50.101 per mitigare e risolvere i 5 CRITICI possibili vettori d'attacco precedentemente analizzati nella fase di scanning.

Fase di REMEDIATION 01: Autenticazione VNC Debole (porta 5900)

- **Strategia di Risoluzione:** La remediation prevede l'eliminazione immediata della credenziale di default "password" e la sua sostituzione con una chiave ad alta sicurezza e complessità, impedendo attacchi di tipo brute-force.
- **Procedura Operativa sulla Macchina Target:**

```
msfadmin@metasploitable:~$ sudo su
[sudo] password for msfadmin: _

msfadmin@metasploitable:~$ sudo vncpasswd
[sudo] password for msfadmin:
Using password file /home/msfadmin/.vnc/passwd
Password:
Warning: password truncated to the length of 8.
Verify:
Would you like to enter a view-only password (y/n)? y
Password:
Warning: password truncated to the length of 8.
Verify:
msfadmin@metasploitable:~$ _
```

"sudo su" (per diventare root), "vncpasswd" invoca l'utility nativa del sistema operativo Linux per la gestione delle credenziali del server VNC. Il comando richiede l'inserimento di una stringa complessa di massimo otto caratteri con caratteri speciali e la sua conferma per sovrascrivere la password precedente.

```
(kali@kali)-[~]
$ vncviewer 192.168.50.101::5900
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication failure
```

Esecuzione sulla macchina Kali di un tentativo di accesso alla porta 5900 con password "password" l'autenticazione ora verrà rifiutata.

Fase di REMEDIATION 02: Rilevamento Backdoor Bind Shell (porta 1524)

- **Strategia di Risoluzione:** La presenza di una shell senza autenticazione richiede la terminazione immediata del processo malevolo e in caso il processo dovesse risorgere, implementare l'utilizzo del firewall per il blocco della porta.
- **Procedura Operativa sulla Macchina Target:**

```
msfadmin@metasploitable:~$ sudo netstat -tulpn | grep 1524
tcp        0      0 0.0.0.0:1524        0.0.0.0:*          LISTEN
4501/xinetd
```

```
msfadmin@metasploitable:~$ sudo kill -9 4501
```

- **netstat -tulpn | grep 1524:** Interroga i socket di rete attivi per identificare il Process ID (PID) del demone(Servizio) associato alla porta 1524.
- **kill -9 [PID]:** Invia un segnale di terminazione forzata (SIGKILL) al kernel per uccidere istantaneamente il processo abusivo(già visto su gameshell.sh).

```
(kali@kali)-[~]
$ nc -nvz -w 2 192.168.50.101 1524
(UNKNOWN) [192.168.50.101] 1524 (ingreslock) : Connection timed out
```

Esecuzione di netcat per tentare di agganciarci alla vecchia backdoor sulla porta 1524. Adesso ad ogni tentativo di aggancio alla porta verrà mostrato a schermo "Connection timed out".

Significhe parametri: -n evita la risoluzione dns, -v attiva la modalità dettagliata, -z attiva il controllo a scansione senza l'invio di dati e -w 2 imposta un timeout di 2 secondi altrimenti continuerà a tentare la connessione in maniera infinita.

AGGIUNTIVO :

- **iptables -A INPUT -p tcp --dport 1524 -j DROP:** Aggiunge una regola di ingresso (INPUT) del firewall per intercettare il protocollo TCP (-p tcp) alla porta 1524 (--dport 1524), scartando i pacchetti (-j DROP).
- **La regola firewall Impedisce al processo killato di risorgere se dovesse succedere**

Fase di REMEDIATION 03: Vulnerabilità Apache Tomcat- Ghostcat (porta 8009)

- **Strategia di Risoluzione:** La risoluzione della vulnerabilità richiede di isolare e aggiornare la presenza del servizio Apache Tomcat rimuovendo l'esposizione del protocollo AJP con la relativa porta(8009) vulnerabile .
- **Procedura Operativa sulla Macchina Target:**

```
msfadmin@metasploitable:~$ sudo nano /etc/tomcat5.5/server.xml
-->
<!-- Define an AJP 1.3 Connector on port 8009 -->
<Connector port="8009"
          enableLookups="false" redirectPort="8443" protocol="AJP/1.3" />
<!-- Define an AJP 1.3 Connector on port 8009 -->
<!-- <Connector port="8009"
          enableLookups="false" redirectPort="8443" protocol="AJP/1.3" />
-->
```

Per risolvere la vulnerabilità **Ghostcat** eliminando l'esposizione del connettore AJP alla radice, si è intervenuti sul file di configurazione del server **Tomcat 5.5** dall'host target al percorso (/etc/tomcat5.5/server.xml). Il blocco del connettore associato alla porta 8009/TCP è stato commentato tramite la sintassi **XML(<!--commento-->)**, impedendo al software di richiamare il demone(Servizio) e aprire il relativo socket.

```
(kali@kali)-[~]
$ nc -nvz -w 2 192.168.50.101 8009
(UNKNOWN) [192.168.50.101] 8009 (?): Connection refused
```

Esecuzione di netcat per tentare di controllare lo stato della porta di ascolto del protocollo AJP sulla porta 8009. Adesso ad ogni tentativo di aggancio alla porta verrà mostrato a schermo "Connection refused" dato che il software non apre più il software di ascolto, eliminando il vettore Ghostcat alla radice.

Significato parametri: -n evita la risoluzione dns, -v attiva la modalità dettagliata, -z attiva il controllo a scansione senza l'invio di dati e -w 2 imposta un timeout di 2 secondi altrimenti continuerà a tentare la connessione.

Fase di REMEDIATION 04: Protocolli di cifratura SSLv2 e SSLv3 Obsoleti (porta 443)

- **Strategia di Risoluzione:** La messa in sicurezza richiede l'immediata riconfigurazione delle librerie crittografiche per vietare gli Handshake basati su SSLv2/v3 e le relative Cipher suite(algoritmi di cifratura) deboli(come il DES), consentendo esclusivamente connessioni basate su standard TLS(sicuro). **Il processo deve essere effettuato per ogni servizio che espone questi protocolli obsoleti come SMTP(porta 25), PostgreSQL (Porta 5432) .**
- **Procedura Operativa di Inibizione dei servizi che espongono SSLv2 e SSLv3:**

```
[ Read 60 lines ]  
msfadmin@metasploitable:~$ sudo nano /etc/apache2/mods-available/ssl.conf  
  
# enable only secure protocols: SSLv3 and TLSv1, but not SSLv2  
SSLProtocol all -SSLv2 -SSLv3 -TLSv1 -TLSv1.1  
SSLProtocol TLSv1.2 TLSv1.3
```

Si interviene modificando la configurazione dei servizi attivi tramite il percorso(/etc/apache2/mods-available/ssl.conf) sulla macchina target, negando SSLv2, SSLv3, TLSv1 o TLSv1.1 ormai non sicuri, mitigando tutti gli attacchi di tipo Downgrade. la rimozione del “#” (commento) permette di rimuovere i servizi obsoleti con il trattino(-) ed invece utilizzare solo protocolli sicuri(TLSv1.2 e TLSv1.3).

```
(kali@kali)-[~]  
$ openssl s_client -connect 192.168.50.101:443 -cipher 'SSLv3'  
40774DADFC7E0000:error:8000006F:system library:BIO_connect:Connection refused:../crypto/bio/bio_sock2.c:183:calling connect()  
40774DADFC7E0000:error:10000067:BIO routines:BIO_connect:connect error:../crypto/bio/bio_sock2.c:185:connect:errno=111
```

Esecuzione del Test del client crittografico integrato di openssl per forzare un handshake usando il protocollo SSLv3 che abbiamo precedentemente disattivato, infatti viene mostrato a schermo “**connect:errno=111**” ovvero “Connection refused” rifiutando in maniera assoluta la connessione con i protocolli obsoleti precedentemente negati in fase di configurazione.

Significato parametri: “s_client”, utility che agisce come un client SSL/TLS generico. Consente di avere una connessione protetta verso un server remoto.

“-connect 192.168.50.101:443”, specifica la destinazione di connessione.

“-cipher ‘SSLv3’” è il parametro che forza il client a proporre solo SSLv3 escludendo i cifrari moderni (TLS).

Secondo metodo, hardening di rete:

hardening di rete delle Porte dei servizi che implementano SSLv2 e SSLv3:

```
msfadmin@metasploitable:~$ sudo iptables -A INPUT -p tcp --dport 443 -j DROP
msfadmin@metasploitable:~$ _
root@metasploitable:/home/msfadmin# iptables -A INPUT -p tcp --dport 25 -j DROP
root@metasploitable:/home/msfadmin# iptables -A INPUT -p tcp --dport 5432 -j DROP
root@metasploitable:/home/msfadmin#
```

Il comando iptables sigilla la porta impedendo ulteriori scansioni esterne e traffico in ingresso per le porte associate ai servizi vulnerabili(Metodo Firewall).

```
(kali㉿kali)-[~]
$ nc -nvz -w 2 192.168.50.101 25
(UNKNOWN) [192.168.50.101] 25 (smtp) : Connection timed out

(kali㉿kali)-[~]
$ nc -nvz -w 2 192.168.50.101 5432
(UNKNOWN) [192.168.50.101] 5432 (postgresql) : Connection timed out

(kali㉿kali)-[~]
$ █
```

Verifica del socket SMTP (Porta 25/TCP): Il tentativo di comunicazione del TCP three-way handshake tramite l'utility netcat ha fallito la negoziazione, restituendo l'errore di **"Connection timed out"** dopo il tempo configurato.

Verifica del socket PostgreSQL (Porta 5432/TCP): L'interrogazione diretta verso il demone del database ha registrato la medesima anomalia di rete, interrompendo la sessione in **"Connection timed out"** senza ricevere alcun pacchetto di risposta (SYN-ACK) dall'host ospite.

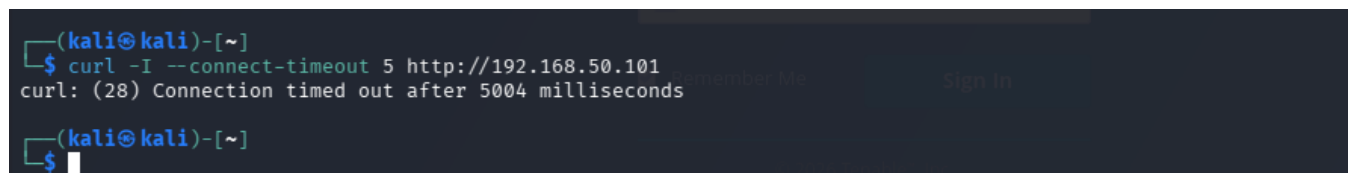
I protocolli SMTP e PostgreSQL implementano l'utilizzo di protocolli datati precedentemente visionati(SSLv2,SSLv3...), per cui è necessario attuare ho una modifica dei file di configurazione delle porte come mostrato nel primo metodo o un hardening di rete tramite firewall per il bloccaggio delle porte.

Fase di REMEDIATION 05: UBUNTU 8.04x

- **Strategia di Risoluzione:** l'unica soluzione per un OS fuori supporto dal 2013 è la migrazione totale su una distribuzione supportata (es. Ubuntu 24.04 LTS) dato che l'aggiornamento di una macchina datata come metasploitable 2 causerebbe il blocco totale della macchina per via di incompatibilità dei servizi e hardware inadatto per nuove versioni ubuntu . Ai fini del laboratorio, e in conformità con la consegna del progetto, si applica una strategia di isolamento perimetrale radicale sulla porta 80 che ha esposto l'OS per la risoluzione della Vulnerabilità.
- **Procedura Operativa sulla Macchina Target:**

```
root@metasploitable:/home/msfadmin# iptables -A INPUT -p tcp --dport 80 -j DROP
root@metasploitable:/home/msfadmin#
```

Spiegazione tecnica del comando: intercettare tutto il traffico in entrata (INPUT) di tipo TCP (-p(protocol) tcp) indirizzato alla porta HTTP standard 80 (--dport 80). L'azione configurata "-j DROP" ordina di dropare ovvero eliminare o cestinare il traffico in modo assoluto, impedendo a malintenzionati sulla rete di interrogare il web server ed estrarre i metadati identificativi del sistema operativo obsoleto.

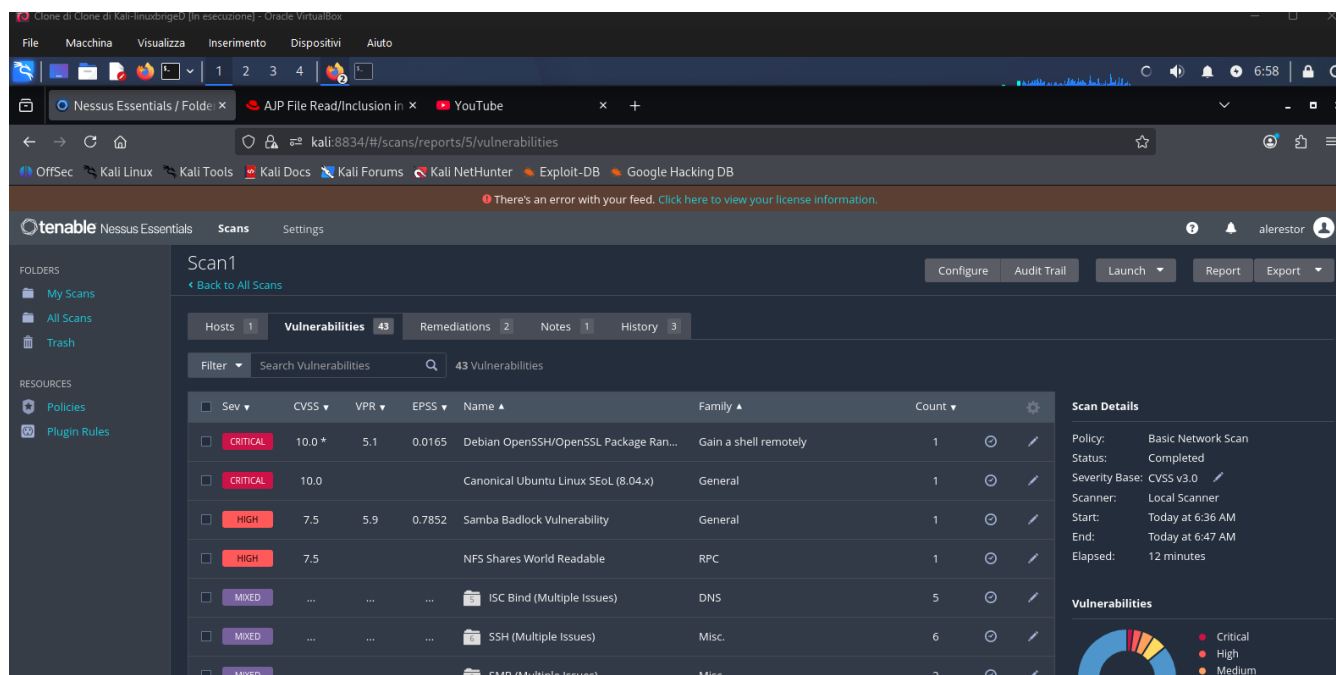


```
(kali㉿kali)-[~]
$ curl -I --connect-timeout 5 http://192.168.50.101
curl: (28) Connection timed out after 5004 milliseconds
(kali㉿kali)-[~]
$
```

Lo screenshot prova l'efficacia della regola del firewall che scarta i pacchetti http tramite l'utility curl con restrizione di tempo(--connect-timeout 5) che ha generato un fallimento immediato e desiderato della sessione . Poiché il server non risponde, diventa impossibile per entità esterne (inclusi i moduli di OS Fingerprinting dello scanner di Nessus) interrogare gli header e catturare la stringa identificativa della distribuzione obsoleta Ubuntu 8.04.

Validazione Finale tramite Rescan di NISSUS (Post-Remediation)

A seguito delle contromisure e tecniche attuate per la risoluzione e mitigazione delle vulnerabilità è stata eseguita una sessione di Rescan mirato tramite la piattaforma Tenable Nessus.



L'attività di scansione automatizzata **post-remediation** ha confermato la corretta risoluzione dei principali vettori CRITICI di attacco. Le vulnerabilità precedentemente classificate con severità CRITICA non sono più state rilevate dallo scanner. Unica Eccezione per la Vulnerabilità "Ubuntu Canonical" che viene ugualmente rilevata dallo scanner dato che il software non è stato aggiornato ma semplicemente bloccata la porta 80 per evitare OS Fingerprinting da parte di eventuali attaccanti.

Conclusioni e stato della remediation

I tentativi condotti da Nessus non hanno ricevuto successo e i vettori d'attacco associati alle varie vulnerabilità sono considerabili completamente risolti e chiusi. Quindi si considera il report del progetto **CONCLUSO**.